Ethical Hacking Assignment 2

ITA14 ETHICAL HACKING

SHAIK THAHEER
192425347

ASSIGNMENT 2-CO2

CO2: Execute footprinting and social-engineering techniques such as DNS analysis, competitive intelligence gathering and attack simulations to collect information for identifying potential security risks.

Nature of Assignment : Individual
Duration : 1 Week
Total Marks : 50
Submission Date : __04-11-2026___

Assignment Title: Evaluation and Engineering of Footprinting, Reconnaissance and Social-Engineering-Awareness Workflows in an Authorized Assessment (Total Marks - 50)

Duration:1week

Scenario — Assessment Design Philosophy

The assignment is designed for high-performing cybersecurity students and emphasizes the evaluation of reconnaissance and information-gathering choices rather than the mechanical use of tools. Students are expected to formulate an information-gathering strategy, construct difficult test conditions, run footprinting against authorized targets, collect evidence, identify limitations, compare alternatives and defend engineering decisions. All work is performed only against authorized or lab-owned targets, and no attack is launched against live systems or real individuals.

The assessment follows: Understand → Predict → Design → Collect → Analyse → Evaluate → Defend → Validate.

Q1 – Evaluate and Engineer a Footprinting Strategy 8 Marks Problem Context – Multi-Source Open-Source Information Gathering

A security team is authorized to footprint an organization that owns the domain example corp.example before a penetration test. Each engagement must gather information from WHOIS, DNS, search engines and public documents, organize it, and use it to understand the target's attack surface.

The team has found that relying on a single source produces an incomplete and sometimes

misleading picture. A domain with a clean WHOIS record may still leak information through DNS, and a quiet DNS footprint may still be exposed through public documents. The strategy must therefore combine several sources and judge their reliability rather than trusting one.

Assessment Challenge

- Design a footprinting strategy that combines passive and active techniques (WHOIS, DNS records, search-engine operators and archived pages) and classify each technique as passive or active.
- Collect information from an authorized domain using appropriate tools such as whois, nslookup and dig, and organize the findings by source.
- Ensure that out-of-scope domains, personal data and unverified results are not treated the same as authorized, verified, in-scope findings.
- Construct four contrasting targets: a well-protected domain; a domain that leaks information; a domain with misconfigured DNS; and a domain with a minimal public footprint.
- For every target, predict what information will be found before collection and compare it with the actual result.
- Record the sources queried and the records found, and identify cases where one source contradicts another.
- Evaluate whether the chosen sources are reliable and whether any source produces misleading or outdated information.

Changed Condition: The scope grows from one domain to fifty subdomains and several third party services. Evaluate the original strategy, modify it where necessary, and defend whether it remains suitable for large-scale authorized reconnaissance.

Evidence Expected: Footprinting strategy design, authorized test targets, collected-source records, prediction-versus-observation analysis, source-reliability analysis, scope analysis and a justified final strategy.

Q2 – Build a Reliable DNS Footprinting Workflow 7 Marks Problem Context – Conflicting and Misconfigured DNS Data

An authorized assessment must map a target's DNS by retrieving A, MX, NS and TXT records and, only where explicitly permitted, attempting a zone transfer. Records may be inconsistent, delegated to third parties, cached or misconfigured, so the workflow must interpret the results carefully rather than reporting them at face value.

Assessment Challenge

- Develop a DNS footprinting workflow using dig and nslookup that retrieves A, MX, NS and TXT records, and attempts a zone transfer only where authorized.
- Evaluate how split-horizon DNS, delegation and caching change the information visible to an external tester.
- Construct at least six contrasting DNS cases, including a correctly secured server, a server

that allows zone transfer, and a server with stale records.

- For each case, predict the records exposed, run the workflow, trace what each query returns, and compare the result with the prediction.
- Evaluate whether a misconfigured zone transfer meaningfully changes the attacker's knowledge and the resulting risk.
- Introduce a countermeasure such as restricting transfers or using TSIG, and redesign the analysis to show the reduced exposure.

Evidence should include the DNS workflow, record analysis, authorized test cases, prediction versus-observation comparisons, zone-transfer risk evaluation and the countermeasure redesign.

Evidence Expected: DNS workflow, record analysis, authorized test cases, prediction versus-observation, zone-transfer risk evaluation and countermeasure redesign.

Q3 – Create a Competitive-Intelligence Awareness Utility 7 Marks Problem Context – Public Information and Human-Risk Exposure

A department is building a repeatable workflow that collects public business information about an authorized organization from job advertisements, annual reports, press releases and public profiles, and assesses how that information could support social-engineering attacks such as phishing, vishing, pretexting and tailgating, so that awareness and countermeasures can be designed. No social-engineering attack is performed against real people.

Your Challenge

- Design documented steps for each public source and record where each item came from, using search-engine operators such as site:, filetype: and intitle:.
- Map each collected item to the social-engineering technique it could enable (phishing, vishing, pretexting or tailgating) and the indicator a target should notice. ● Create test organizations containing rich, sparse and misleading public information. ● Predict the information and the human-risk level expected from each source before collection.
- Evaluate whether the collected information meaningfully increases social-engineering risk and which source is the most dangerous.
- Add two new sources or two new awareness countermeasures without restructuring the whole workflow, and evaluate the effect.
- Record the sources queried, the items found and the countermeasures recommended.

Inquiry

Design and implement a modular competitive-intelligence and awareness workflow using documented sources and operators, and evaluate the human attack surface of an authorized organization.

Evidence should include the workflow architecture, source operators, item-to-technique mapping, test organizations, prediction-versus-observation and recommended countermeasures.

Evidence Expected: Workflow architecture, source operators, item-to-technique mapping, test organizations, prediction-versus-observation, risk evaluation and recommended countermeasures.

Q4 – Design a Reconnaissance Data-Validation Mechanism 6 Marks Problem Context –

High-Stakes Reconnaissance Data Quality

A reconnaissance data-collection process receives results that may be incomplete, outdated, duplicated or out of scope. Acting on poor-quality data wastes effort and can breach the agreed scope, so each item must be validated before it is used.

Your Challenge

- Develop a validation mechanism that checks each collected item for scope, freshness, duplication and source reliability.
- Distinguish a recoverable item (one that needs a re-query or confirmation) from an item that must be rejected (out of scope or unverifiable).
- Construct at least five test sequences, including all-valid, out-of-scope, stale and duplicated data.
- Predict how many items pass, fail or need re-checking before running the validation. ● Evaluate whether the order of the validation checks affects effort and accuracy. ● Redesign the validation order to reduce unnecessary checks while still keeping out-of-scope data out.

Scalability Inquiry

Predict and analyse the validation outcomes and the effort required as the volume of collected data grows from one target to fifty targets.

Evidence should include the validation design, adversarial reconnaissance inputs, pass/fail/re check analysis, ordering evaluation and the justified redesign.

Evidence Expected: Validation design, adversarial reconnaissance sequences, pass/fail/re-check analysis, ordering evaluation and a justified redesign.

Q5 – Evaluate Footprinting of a Hierarchical Organization 7 Marks Problem Context –

Irregular Multi-Level Organizational Footprint

A target organization has a nested public footprint of a parent domain, subdomains, departments and third-party services. Footprinting must traverse this hierarchy level by level, recording each level and stopping cleanly at out-of-scope or terminal nodes.

Your Challenge

- Represent the organization's public footprint as a hierarchy (domain, subdomains and services) that can be traversed systematically.
- Develop a systematic traversal that records each level and stops at out-of-scope or terminal nodes using an explicit boundary condition.
- Construct shallow, deeply nested and irregular footprints with branches of differing size. ●

Predict the number of nodes and the information expected before the traversal. ● Evaluate how depth and branching affect the effort and completeness of the footprinting. ● Include an empty branch or a node with no public data and evaluate whether the boundary condition handles it correctly.
● Compare the systematic traversal conceptually with an ad-hoc, unstructured approach.

Test Your Design

Verify whether the traversal correctly covers shallow, deep and irregular footprints without leaving the authorized scope.

Correctness Inquiry

Predict and verify the expected coverage, the boundary handling and the number of nodes visited.

Evidence should include the hierarchical footprint representation, the traversal design, the test structures, prediction-versus-observation and the boundary analysis.

Evidence Expected: Hierarchical footprint representation, traversal design, test structures, prediction-versus-observation, boundary analysis and a justified final design.

Q6 – Evaluate Footprinting Approaches Under Constraints 7 Marks Problem Context – Reconnaissance Under Time and Stealth Constraints An authorized assessment must gather enough information while balancing speed, completeness and the risk of detection. Passive open-source collection and more active footprinting have different trade-offs, so the better approach depends on the scope and the constraints.
Your Challenge
● Select two information-gathering approaches, for example passive open-source collection versus active DNS and service footprinting, and define what each produces. ● Apply both approaches to the same authorized target.
● Test at least four increasing scope sizes, including one at which one approach becomes impractical.
● Record the number of queries or steps and the time taken where useful. ● Evaluate redundant or repeated collection in each approach and identify where effort is wasted.
● Determine whether the faster or the quieter approach is always the better engineering choice.
● Defend a recommendation for a small-scope engagement and for a large-scope engagement.

Inquiry
The workflow is used both for teaching and for repeated real assessments; justify the chosen approach for each context.

Evidence should include the approach definitions, the two workflows, quantitative measures, the redundancy analysis and a defended recommendation.

Evidence Expected: Approach definitions, two workflows, quantitative measures, redundancy analysis and a defended recommendation.

DAY-4 DESIGN CHALLENGE

Q7 – Integrated Review: Diagnose, Redesign and Defend 8 Marks Select one workflow from Q1–Q6 that demonstrates a meaningful limitation, such as incomplete coverage, an unreliable source, excessive queries, weak validation or a risk of leaving scope, and improve it using evidence.

A. Diagnose the Limitation 2 Marks ● Identify the reconnaissance or logical bottleneck using evidence.

● Determine whether the limitation is caused by source unreliability, redundant collection, poor ordering or a risk of going out of scope.

EVIDENCE EXPECTED

- Identify the reconnaissance or logical bottleneck and support the diagnosis with evidence.
- Pinpoint the underlying cause of the limitation, such as redundant collection, an unreliable source or poor ordering.

B. Establish Evaluation Criteria 1 Mark ● Define measurable criteria against which the original workflow will be judged. ● Examples include coverage, the number of queries, source reliability, scope compliance and time.

Evidence Expected

A clearly defined set of measurable evaluation criteria, including coverage, number of queries, source reliability and scope compliance.

C. Propose and Implement a Redesign 2 Marks ● Modify the original workflow to address the diagnosed limitation.

● Provide the design logic or the ordered steps before implementation.
● Identify any trade-off introduced by the redesign.

Evidence Expected

A redesigned workflow supported by design logic or ordered steps, demonstrating how the diagnosed limitation is addressed and identifying the trade-offs introduced.

D. Validate and Compare 2 Marks ● Use equivalent test conditions for the original and the redesigned workflow. ● Collect quantitative evidence and determine whether the redesign actually improves the selected criterion.

Evidence Expected

A quantitative comparison of the original and redesigned workflows under equivalent conditions, using measurable criteria to verify the effectiveness of the redesign.

E. Defend the Final Engineering Judgment 1 Mark ● Evaluate whether the redesign met its objective.

● Explain cases in which the original workflow may still be preferable. ● Defend the final choice using experimental evidence rather than subjective statements.

Evidence Expected

A justified final engineering decision supported by experimental results, evaluating the redesign's effectiveness and identifying cases in which the original workflow remains preferable.

MARK DISTRIBUTION

Question	**Assessed Area**	**Marks**
Q1	Footprinting strategy design and evaluation	8
Q2	DNS footprinting and analysis workflow	7
Q3	Competitive-intelligence and awareness utility	7
Q4	Reconnaissance data validation and recovery	6
Q5	Hierarchical organization footprinting	7
Q6	Footprinting approach comparison	7
Q7	Integrated diagnose–redesign–validate challenge	8
TOTAL		**50**

Submission Requirements

Submit:

● Assignment report containing evidence for Q1–Q7.
● Scripts or documented command sequences for all implemented workflows.

- Student-designed authorized test targets and adversarial cases.
- Raw collected data and tool outputs.
- Prediction-versus-observation comparisons.
- Tables/graphs wherever they strengthen the evaluation.
- Source, query, item and scope counts where applicable.
- Design representation or pseudocode for redesigned workflows.

Execution time may be reported as supporting evidence, but conclusions should not rely solely on timing; coverage, source reliability and scope compliance should form the primary evidence.

Assessment Verification / Viva

Students may be asked to explain and defend their source selection, footprinting methodology, DNS and open-source analysis, scope and authorization decisions, social engineering-awareness reasoning, adversarial test design, measured results, redesign choices and final engineering judgments.

Overall Assessment Expectation

The assignment assesses the student's ability to evaluate information-gathering solutions under realistic, authorized conditions: Problem Interpretation → Prediction → Design → Collection → Adversarial Testing → Measurement → Analysis → Evaluation → Defence → Engineering Judgment.

DECLARATION, ABSTRACT AND REPORT GUIDE

Declaration

I declare that this report is prepared for ITA14 Ethical Hacking Assignment 2. All workflows and test cases are designed for authorized or lab-owned targets only. No attack is launched against live systems or real individuals. Simulated outputs are clearly labelled and must not be represented as actual collection.

Abstract

This report engineers a repeatable reconnaissance workflow combining WHOIS/RDAP, DNS, search-engine operators, public documents and archived pages. It evaluates DNS interpretation, competitive-intelligence awareness, data validation, hierarchical footprint traversal, passive-versus-active approaches and an integrated redesign. The method follows Understand → Predict → Design → Collect → Analyse → Evaluate → Defend → Validate.

Assumptions and boundaries

- Training namespace: example-corp.test; illustrative only, not a real organization.
- Run commands only against domains, resolvers and VMs owned by the student or explicitly authorized in writing.
- Example observations and quantitative comparisons are simulated design data, not real target claims.
- Social-engineering analysis is awareness-only: no phishing, vishing, pretexting, tailgating or employee contact.
- Third-party services are out of scope unless separately authorized by the owner and covered by contract.

Report organization

Q1–Q6 design and evaluate the required workflows. Q7 diagnoses a limitation, defines metrics, redesigns the workflow, validates the redesign and defends the final engineering choice.

Q1 – EVALUATE AND ENGINEER A FOOTPRINTING STRATEGY (8 MARKS)

1.1 Problem interpretation

The assessment team must understand an authorized organization's external information footprint before a penetration test. WHOIS may be privacy-protected; DNS may reveal infrastructure; search engines may index old pages; public documents may disclose roles or suppliers; archives may retain retired content. No single source provides a complete or necessarily current picture.

Objectives

1. Confirm the authorized root domain, permitted subdomains and third-party boundaries.
2. Collect registration metadata, DNS records, indexed pages, public documents and historical pages.
3. Classify each technique as passive or active and record operational impact.
4. Predict findings for contrasting target profiles before collection.
5. Compare predictions with observations and resolve contradictions.
6. Rate freshness, source reliability, scope and sensitivity before using an item.

Scope classes

Class	Example	Treatment
In scope	example-corp.test and named approved subdomains	Collect within signed scope.
Conditional	Hosted mail or LMS vendor	Separate owner/contract permission required.
Out of scope	Unlisted supplier domain or personal website	Do not enrich or probe.
Sensitive	Private contact details, credentials, personal data	Exclude by default; minimize if explicitly approved.

A public link, CNAME, organizational relationship or discovered hostname does not create authorization.

Q1 – SOURCE STRATEGY AND CLASSIFICATION

Source	Classification	Information	Limitations
WHOIS/RDAP	Passive lookup	Registrar, dates, status, nameservers, registrant where visible	Privacy redaction and registry lag.
DNS A/MX/NS/TXT	Low-impact active query	Addresses, mail routing, authoritative DNS, TXT policy	Caching, delegation and split-horizon.
Search operators	Passive	Indexed pages, documents and technology references	Stale or incomplete index.
Public reports/job adverts	Passive	Departments, roles, suppliers and projects	Publication date may be old.
Web archives	Passive	Historical pages and retired paths	Not proof of current service.
Direct service probing	Active; separate approval	Service metadata and exposure	Can trigger alerts or service impact.

Recommended staged strategy

7. Authorization and boundary validation.
8. Passive collection from registry, search engines, official documents and archives.
9. DNS confirmation for exact approved names only.
10. Reconcile contradictions and label historical information.
11. Privacy and scope review; reject unrelated domains and personal details.
12. Produce a structured inventory with provenance and confidence.

Q1 – TOOLING AND DOCUMENTED COMMAND SEQUENCES

WHOIS / RDAP

```
whois example-corp.test
# Training namespace; use a local fixture or supplied mock output.
```

Record registrar, creation/expiry dates, status, nameservers and registrant organization only where public. A reserved training domain may have no live registration record; use a mock record rather than querying an unrelated real domain.

DNS commands

```
dig example-corp.test A
dig example-corp.test MX
dig example-corp.test NS
dig example-corp.test TXT
nslookup -type=A example-corp.test
nslookup -type=MX example-corp.test
```

Search operators

```
site:example-corp.test filetype:pdf
site:example-corp.test intitle:"annual report"
site:example-corp.test "careers" OR "vacancies"
```

Review only public results. Open the first-party page, record its publication date and context, and do not treat a search snippet as verified evidence.

Collection record fields

Field	Purpose
item_id	Unique identifier, e.g. FP-001.
source_type / source_ref	WHOIS, DNS, search, document or archive; query/URL.
observed_value	Minimal relevant information.
observed_at / source_date	Collection timestamp and original date.

scope_status	IN_SCOPE / CONDITIONAL / OUT_OF_SCOPE.
confidence	HIGH / MEDIUM / LOW with reason.
sensitivity	PUBLIC / INTERNAL / PERSONAL / SECRET.
validation_status	PASS / RECHECK / REJECT.

Q1 – CONTRASTING TARGET PROFILES

Four constructed profiles are used to demonstrate prediction-versus-observation. The observations below are simulated teaching data.

Profile	Prediction	Simulated observation	Evaluation
Well-protected	WHOIS privacy; few DNS records and indexed documents.	Privacy-redacted registration; basic A/NS/MX; official pages only.	Low visible exposure; absence of evidence is not proof of absence.
Information-leaking	Public job ads, old PDFs and technology references.	Old org chart, supplier name and legacy hostname references.	Moderate exposure; verify freshness and avoid personal data.
Misconfigured DNS	Excessive/stale records and unnecessary TXT text.	Retired host alias and unnecessary TXT string in fixture.	Hygiene issue; confirm owner status and data sensitivity.
Minimal footprint	Few indexed pages and minimal public DNS.	Home page and basic NS/MX only.	Limited observable footprint; source coverage may be incomplete.

Prediction-versus-observation method

Write predictions before collection to reduce hindsight bias. A stale hostname is not automatically a vulnerability; it may be retired. A supplier name in a job advert may describe

a planned migration. Record the discrepancy, seek owner confirmation and do not probe unlisted systems.

Confidence model

Level	Criteria	Decision
High	Current first-party source plus independent confirmation.	Use in verified inventory.
Medium	One credible source or two secondary sources.	Use with caveat; confirm before test planning.
Low	Old archive, unattributed mention, snippet only or conflict.	Re-query or reject; do not direct testing.

Contradiction example

A search result lists oldmail.example-corp.test while current MX records point to a hosted mail provider. Record the old result as historical/low confidence, the current MX as current DNS evidence, and request owner confirmation. Do not probe the legacy name unless explicitly listed.

Changed condition: 50 subdomains and third parties

- Use a signed asset manifest rather than a free-form list.
- Group subdomains by owner, environment and data class.
- Obtain separate written permission for vendor-owned services.
- Apply query budgets, deduplication, rate limits and caching.
- Automate only approved names and preserve raw results with timestamps.
- Require human review for personal data, uncertain ownership and wildcard DNS.

Decision: multi-source passive-first collection remains suitable at 50 targets only with manifest-driven scope, provenance, deduplication and third-party approval.

Q2 – RELIABLE DNS FOOTPRINTING WORKFLOW (7 MARKS)

Record	Meaning	Assessment relevance
A	Hostname to IPv4 address	Identifies published IPv4 endpoint.
MX	Mail exchanger and preference	Shows mail routing/provider.
NS	Authoritative nameservers	Shows DNS delegation.
TXT	Text policy/verification records	May reveal SPF, DKIM, DMARC or service metadata.

Safe query sequence

```
dig example-corp.test A
dig example-corp.test MX
dig example-corp.test NS
dig example-corp.test TXT
nslookup -type=A example-corp.test
nslookup -type=MX example-corp.test
```

Run only against the approved lab domain/resolver. Capture question, answer, authority/additional sections, TTL, resolver, timestamp and response code. Empty answers must be interpreted with response status and record type.

Zone-transfer boundary

AXFR is not part of the default workflow. Attempt it only against a DNS server and zone owned by the student or explicitly authorized in writing. The assignment's AXFR cases can be represented by a local DNS lab or simulated transcript.

```
dig @192.0.2.53 example-corp.test AXFR
# Documentation-only IP; use only your own isolated lab DNS server.
```

Never attempt AXFR against public or university domains without explicit written authorization.

Q2 – DNS WORKFLOW AND INTERPRETATION

13. Validate scope manifest: root zone, allowed names and approved resolver.
14. Query A, MX, NS and TXT with dig; confirm selected results using nslookup.
15. Record TTL, response code, answer count, authority section and timestamp.
16. Compare recursive and authoritative answers only in an authorized lab.
17. Check delegation and identify child zones hosted elsewhere.
18. Assess caching by comparing answers around TTL expiry in a controlled zone.
19. Consider split-horizon by comparing approved lab vantage points.
20. Perform AXFR only on owned lab zone; record success/refusal.
21. Apply countermeasure and repeat identical queries.

Pseudocode

```
FOR domain in approved_scope:
  FOR type in [A, MX, NS, TXT]:
    result = query_dns(domain, type, approved_resolver)
    record(result, timestamp, resolver, scope_id)
  IF AXFR explicitly authorized for owned lab:
    record(axfr_test(lab_nameserver, domain))
  ELSE:
    record('AXFR NOT ATTEMPTED: NOT AUTHORIZED')
```

Interpretation

A DNS answer describes what the queried resolver returned at that time. Recursive caches can retain answers until TTL expiry. Split-horizon DNS can return different internal and external views. A delegated child zone may be operated by a vendor; delegation does not include the vendor's entire infrastructure in scope.

Q2 – SIX CONTRASTING DNS CASES

Case	Prediction	Simulated observation	Interpretation
Secured server	Normal records; AXFR refused.	A/MX/NS/TXT returned; AXFR REFUSED.	Secure transfer baseline.
AXFR open in lab	Zone contents returned.	12 synthetic host records exposed.	More complete host map; not proof of vulnerability.
Stale record	Retired hostname remains.	legacy-app points to retired test IP.	Confirm owner status; may mislead.
Split-horizon	Different internal/external answers.	Private lab IP internally; public test IP externally.	Vantage point changes results.
Delegated subdomain	Child NS points elsewhere.	research child delegated to lab vendor DNS.	Separate permission required.
Minimal zone	Few records.	A, NS and MX only; no TXT.	Limited public footprint, not proof of no systems.

Risk of zone transfer

An unrestricted AXFR may reveal hostnames, environment names, mail systems, VPN labels, internal naming conventions or retired systems. It increases reconnaissance knowledge but does not prove that a listed service is vulnerable. Risk depends on sensitivity and usefulness of zone contents.

Countermeasures

- Allow AXFR only from explicitly configured secondary DNS addresses.
- Use TSIG to authenticate transfers between authorized DNS peers.
- Monitor and alert on unexpected transfer requests.

- Remove stale and unnecessary records; separate public and internal zones.

Q2 – COUNTERMEASURE REDESIGN

Test	Before restriction	After restriction
Authorized secondary	Transfer succeeds in lab.	Transfer succeeds only from listed secondary.
Unlisted client	Transfer succeeds in intentionally vulnerable fixture.	Transfer refused.
Unauthenticated request	May retrieve zone in vulnerable fixture.	TSIG validation rejects request.
Ordinary public query	A/MX/NS/TXT answers visible.	Normal public answers remain visible.

Redesign experiment

22. Create a local authoritative DNS zone with synthetic records.
23. Capture baseline A/MX/NS/TXT answers and AXFR result.
24. Configure an allow-listed secondary address and TSIG in the lab.
25. Repeat AXFR from an unlisted lab client and confirm rejection.
26. Repeat from authorized secondary and confirm replication still works.
27. Compare exposed record count and operational impact.

Engineering decision: combine source allow-listing with TSIG where supported. IP restrictions alone are not authentication; TSIG alone does not replace network controls. Misconfigured AXFR meaningfully improves an observer's map of the environment, so transfers should be restricted and monitored.

Q3 – COMPETITIVE-INTELLIGENCE AWARENESS UTILITY (7 MARKS)

Purpose and ethical boundary

The utility collects public business information to assess what a malicious actor might infer and to design awareness controls. It does not contact employees, send phishing messages, make calls, impersonate staff or attempt physical entry. The output is an organizational exposure assessment, not a list of people to target.

Module	Input	Output
Source planner	Approved organization/source categories	Query plan and source register.
Public collector	Job ads, reports, releases, public profiles	Minimal public facts with source/date.
Normalizer	Collected facts	Deduplicated records.
Technique mapper	Fact type and context	Potential human-risk pattern.
Risk assessor	Likelihood, impact, freshness, confidence	Exposure rating.
Awareness recommender	Risk and indicator mapping	Training and defensive controls.
Reviewer	Legal/privacy review	Approved awareness report.

Source categories

- Job advertisements: technology stack, roles, tools and work locations.
- Annual reports: business units, suppliers, governance and projects.
- Press releases: project dates, partnerships and public events.
- Official public profiles: role responsibilities and official contact channels; avoid private details.

Q3 – SEARCH OPERATORS AND SOURCE RECORDS

site:example-corp.test careers

site:example-corp.test filetype:pdf "annual report"

site:example-corp.test intitle:"press release"

site:example-corp.test "IT support"

Use operators to locate public information only. Verify the first-party source, context and publication date. Search snippets alone are low-confidence.

ID	Source	Simulated public item	Potential implication
CI-01	Official job advert	Cloud identity administration role.	Could support helpdesk-themed phishing awareness.
CI-02	Annual report PDF	Hosted LMS provider named.	Vendor-themed impersonation; verify vendor requests.
CI-03	Press release	Campus network upgrade month.	Urgency pretext; confirm through official IT channel.
CI-04	Public profile	Department role and official office contact.	Tailored impersonation; independently verify identity.
CI-05	Event page	Visitor registration process.	Tailgating awareness; enforce badges and escorts.

Data minimization

Do not build dossiers of private individuals. Store role-level facts and source URLs. Exclude personal phone numbers, home addresses, family details and unrelated information. A public profile is not permission to use its information to target a person.

Q3 – ITEM-TO-TECHNIQUE AND INDICATOR MAPPING

Public item	Potential technique	Warning indicator	Countermeasure
Job advert names helpdesk tools	Phishing	Unexpected account reset link or software install request.	Use official service portal; report suspicious mail.
Vendor in annual report	Pretexting/phishing	Urgent vendor access or invoice request.	Verify using saved vendor contact and procurement process.
Office phone listed	Vishing	Caller asks for OTP or MFA approval.	Never share codes; call back using directory.
Upgrade timeline	Pretexting	Urgent request to bypass change process.	Confirm via official status page.
Visitor process	Tailgating	Unknown person asks to follow through secure door.	Do not badge others in; direct to reception.

This is a prioritization aid, not a validated probability model. Explain each score and have the organization review it.

Q3 – TEST ORGANIZATIONS AND PREDICTIONS

Organization	Public profile	Predicted risk	Simulated outcome
Org A – Rich	Reports, detailed job ads, vendors and events.	High contextual exposure.	Many current role/vendor facts; highest context.
Org B – Sparse	Basic home/contact pages only.	Low–moderate.	Few tailored facts; generic scams still possible.

Org C – Misleading	Old adverts, outdated supplier notice, archived event.	Moderate but uncertain.	Conflicts with current pages; label stale.

Q3 – AWARENESS COUNTERMEASURES AND EXTENSIONS

- Publish an easy channel to report suspicious email, calls and visitor behaviour.
- Require independent call-back for sensitive requests.
- Never share passwords, OTPs or MFA approval codes.
- Verify vendor and bank-detail changes through separate trusted channels.
- Enforce visitor registration, visible badges and escort rules.
- Train staff to recognize urgency, secrecy, authority pressure and unusual requests.

Extension	Added module	Expected effect
Public procurement notices	Capture supplier/process facts with dates.	Adds invoice and supplier impersonation scenarios.
Public event calendars	Capture event-level logistics only.	Improves visitor awareness without profiling individuals.
Verified call-back	Checklist plus trusted directory reference.	Reduces caller-ID spoofing and authority pretexts.
Visitor challenge protocol	Reception escalation, badges and no-tailgating reminder.	Reduces unauthorized physical following.

New sources broaden scenarios but increase stale/duplicate information. The controls address human actions directly and may reduce risk more reliably than simply collecting more data.

Q4 – RECONNAISSANCE DATA-VALIDATION MECHANISM (6 MARKS)

Every item must be checked before it informs the attack-surface inventory or awareness analysis. Validation dimensions are scope, freshness, duplication and source reliability, with an immediate privacy screen.

State	Definition	Action
PASS	In scope, sufficiently current, unique and supported.	Use with provenance.
RECHECK	Potentially useful but stale, ambiguous, conflicting or weakly sourced.	Re-query approved source or ask owner.

REJECT	Out of scope, unverifiable, unnecessary sensitive data or duplicate.	Exclude and record reason.

Safe-first validation order

28. Scope gate: verify authorized domain/asset first.
29. Privacy gate: remove or reject unnecessary personal/sensitive data.
30. Duplicate check: compare normalized URL, record type/value and content hash.
31. Freshness check: compare observation and publication dates.
32. Reliability check: evaluate authority, corroboration and context.
33. Disposition: PASS, RECHECK or REJECT with reason and reviewer.

Scope is checked first because an out-of-scope item must not trigger enrichment or active queries. Privacy screening follows immediately to minimize handling.

Q4 – VALIDATION TEST SEQUENCES

Test	Input	Predicted result	Reason
All valid	5 current unique official in-scope records.	5 PASS	All gates satisfied.
Out of scope	2 unrelated vendor-domain records.	2 REJECT	Scope fails.
Stale	2 old archived host references.	2 RECHECK	Historical status needs confirmation.
Duplicates	3 copies of one PDF.	1 PASS + 2 duplicate rejects	Retain canonical record.
Mixed	1 official, 1 personal phone, 1 forum claim, 1 old vendor name.	1 PASS, 2 REJECT, 1 RECHECK	Privacy, reliability and freshness.

Nine-item example batch

Item	Scope	Freshness	Duplicate	Reliability	Result

V1	In	Current	No	High	PASS
V2	In	Current	No	High	PASS
V3	In	Current	No	Medium	PASS
V4	In	Current	No	High	PASS
V5	In	Current	No	High	PASS
V6	In	Old	No	Medium	RECHECK
V7	In	Current	Yes	High	REJECT duplicate
V8	Out	Current	No	High	REJECT scope
V9	In	Unknown	No	Low	RECHECK / reject if unverifiable

Prediction: 5 PASS, 2 RECHECK and 2 REJECT. These are illustrative inputs, not live collection.

Q4 – VALIDATION EFFORT AND SCALABILITY

Illustrative disposition for the nine-item batch: five pass, two require re-check and two are rejected.

Does check order matter?

Order	Sequence	Effect
Original broad order	Freshness → reliability → duplicate → scope	Wasted work; out-of-scope data may be enriched.
Redesigned order	Scope → privacy → duplicate → freshness → reliability	Rejects unsafe items early and reduces repeated review.

Scale from one to fifty targets

Targets	Items at 10 per target	Handling
1	10	Manual review feasible.
5	50	Spreadsheet or small database.

10	100	Structured import and validation rules.
50	500	Automated pre-filter and human exception queue.

Q5 – HIERARCHICAL ORGANIZATION FOOTPRINTING (7 MARKS)

Represent the public footprint as a rooted tree or directed graph. The root is the authorized parent domain. Child nodes may represent subdomains, departments, web apps or third-party services. Visit only authorized nodes.

Level	Example	Possible children
0 Root	example-corp.test	www, mail, portal, departments
1 Subdomain	portal.example-corp.test	login, api, help
2 Department	research.example-corp.test	repository, project page
3 Dependency	lms-vendor.example	Third-party service; separate permission
Boundary	External supplier / no public data	Stop and record reason.

Explicit stop conditions

- Node is not in approved scope manifest.
- Node is third-party without separate permission.
- No public data after approved passive checks.
- Node is duplicate alias already visited.
- Depth or query budget reached.
- Never infer permission from CNAME or hyperlink.

Q5 – TRAVERSAL ALGORITHM AND TEST STRUCTURES

Breadth-first traversal pseudocode

```
queue = [authorized_root]; visited = set()
WHILE queue:
  node = queue.pop(0)
  IF node in visited: continue
```

```
visited.add(node)
IF not scope_allows(node): record_boundary(node); continue
IF third_party(node) and not separately_approved(node):
    record_boundary(node); continue
result = collect_approved_public_metadata(node)
record(node, result)
IF result.empty: record_terminal(node); continue
FOR child in approved_children(result):
    IF child not in visited: queue.append(child)
```

Structure	Shape	Predicted nodes	Expected result
Shallow	Root → 3 children	4	Visit all authorized leaves.
Deep	Root → A → B → C → D	5	Visit each level until terminal/depth limit.
Irregular	Deep branch, empty branch, broad branch	8 (example)	Empty branch terminal; broad branch covered.
Third party	Root → vendor CNAME	1 + boundary	Do not traverse vendor without permission.

An empty branch is not a failure. Record NO_PUBLIC_DATA and stop that branch; do not guess child names.

Q5 – COVERAGE, COMPLEXITY AND AD-HOC COMPARISON

Test	Predicted	Observed	Boundary
Shallow	4	4	All leaves reached.
Deep	5	5	No parent-child gap.
Irregular	8	8	Empty branch terminal.
Third-party	1 + boundary	1 + boundary	Vendor not traversed.

Approach	Strength	Weakness

Systematic	Repeatable coverage, explicit boundary, deduplication and audit.	Needs accurate manifest and normalization.
Ad hoc	Fast for small familiar targets.	May miss branches, repeat work or follow external links.

Q6 – FOOTPRINTING APPROACHES UNDER CONSTRAINTS (7 MARKS)

Approach	Activities	Output	Trade-off
Passive OSINT	WHOIS/RDAP, search, official documents, archives.	Public inventory with dates/confidence.	Quiet but index freshness varies.
Active DNS	A/MX/NS/TXT queries against approved names.	Current DNS, TTL, delegation and mail view.	Structured but generates queries and resolver-specific view.

Both approaches use the same synthetic authorized target set, example-corp.test, across 1, 5, 10 and 50 target groups. Counts are simulated workload estimates, not live telemetry.

Measurement definitions

- Coverage = approved target groups with at least one validated observation.
- Query/step count = distinct lookups or DNS query operations.
- Redundancy = repeated observations with no new information.
- Freshness = items within the agreed age threshold.
- Scope compliance = collected items matching approved manifest.
- Elapsed time is supporting evidence, not the sole decision metric.

Q6 – QUANTITATIVE COMPARISON

Scope	Passive steps	DNS queries	Passive coverage	DNS coverage
1	4	6	95%	100%
5	12	30	92%	100%
10	20	60	90%	100%

50	100	300	88%	98%

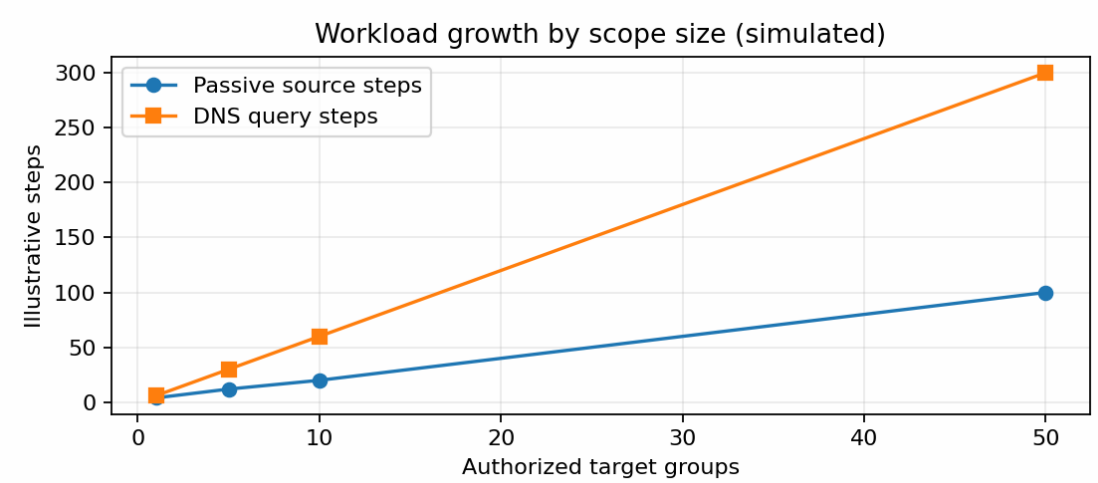


Figure 1. Simulated workload growth by scope size.

Redundancy analysis

Search may return the same PDF under multiple URLs; DNS may repeat identical answers through aliases or resolvers. Deduplicate by canonical URL, content hash, normalized hostname, record type and value. Preserve timestamps and TTL so cached answers are not treated as current.

Q6 – RECOMMENDATION AND ENGINEERING JUDGMENT

Neither faster nor quieter is always better. Passive collection may miss current DNS exposure; DNS queries may provide a more current answer but create logs and still be affected by caching or split-horizon.

Context	Recommendation	Reason
Small (1–5)	Passive-first plus limited DNS confirmation.	Manual review manageable; low noise.
Medium (10)	Hybrid collection with scripted, rate-limited DNS and deduplication.	Repeatability becomes important.
Large (50)	Manifest-driven automation, query budget, provenance and human exception review.	Manual collection inefficient; controls prevent scope drift.

High sensitivity	Passive sources first; obtain explicit approval before DNS interaction.	Minimizes interaction.

Q7 – INTEGRATED REVIEW: DIAGNOSE AND CRITERIA (8 MARKS)

7.1 Selected workflow and limitation

Selected workflow: Q4 validation. The original ordering checked freshness and source reliability before scope. This can waste effort on unrelated domains and risks enriching data outside the approved boundary.

Weakness	Evidence	Consequence
Scope checked late	Mixed batch includes two out-of-scope items.	Unnecessary enrichment before rejection.
Duplicate check late	Same PDF appears three times.	Repeated review and inflated counts.
Privacy screen missing	Public profile contains personal contact data.	Unnecessary personal-data handling.
No separate re-check state	Stale and unverifiable items grouped together.	Uncertain facts may be treated as confirmed.

7.2 Evaluation criteria

Criterion	Measure	Target
Scope compliance	Out-of-scope items enriched/used	Zero
Coverage	Valid unique items retained / valid inputs	≥95%
Effort	Validation operations	Lower than original
Reliability	Items with complete provenance	100%
Privacy	Unnecessary personal data retained	Zero
Disposition	Correct status against test oracle	100%

Q7 – REDESIGN AND IMPLEMENTATION LOGIC

7.3 Redesigned order

34. Normalize URL, hostname, record type and timestamp without enrichment.
35. Apply scope allow-list immediately; reject unlisted domains.
36. Apply privacy/sensitivity screen and minimize or reject unnecessary personal data.
37. Deduplicate by canonical URL, normalized value and content hash.
38. Check freshness; stale items go to RECHECK.
39. Assess source reliability; weak claims go to RECHECK or REJECT if unverifiable.
40. Assign final status, reason, reviewer, timestamp and evidence reference.

Pseudocode

```
FUNCTION validate(item, manifest):
  item = normalize(item)
  IF NOT manifest.allows(item.domain): REJECT('OUT_OF_SCOPE')
  IF unnecessary_personal_data(item): minimize_or_REJECT()
  IF duplicate(item): REJECT('DUPLICATE')
  IF stale(item): RECHECK('STALE')
  IF reliability(item) < threshold:
    IF confirmable(item): RECHECK('LOW_CONFIDENCE')
    ELSE: REJECT('UNVERIFIABLE')
  PASS('VALIDATED')
```

Trade-off: an early reject may discard a potentially useful lead. If the owner wants it assessed, request a formal scope amendment rather than silently enriching it.

Q7 – VALIDATION AND COMPARISON

Both workflows receive the same nine-item batch: five current official in-scope items, one stale item, one duplicate, one out-of-scope item and one low-confidence item.

Metric	Original	Redesigned	Finding
Items received	9	9	Same input.
Scope checks	9, late	9, first	Safer order.
Reliability reviews	9	6	Three unnecessary reviews avoided.

Duplicate reviews	3 copies	1 canonical	Repeated effort reduced.
PASS	5	5	Coverage preserved.
RECHECK	2	2	Uncertainty retained.
REJECT	2	2	Out-of-scope and duplicate excluded.
Out-of-scope enrichment	Possible	0	Scope protection improved.

Interpretation

The final disposition totals remain the same because both processes use the same test oracle. The redesign improves the order of work: out-of-scope items are rejected before enrichment, duplicates are removed early and privacy is screened before detailed analysis. Three reliability reviews are avoided without losing valid coverage.

Evidence limitation: these are simulated counts. For an implementation submission, run the validator against a CSV/JSON fixture and attach raw program output and timestamps.

FINAL ENGINEERING DEFENCE AND CONCLUSION

Final engineering judgment

The redesigned validator is selected for repeated assessments because it applies the authorization boundary first, minimizes personal data, removes duplicates early and preserves uncertainty with a separate RECHECK state. The original order may be acceptable for a tiny exploratory task where all items are already known to be in scope, but scope should still be checked first.

Q1–Q7 summary

- Q1: Multi-source passive-first collection improves coverage; large scope needs manifests and third-party approval.
- Q2: DNS answers require TTL, delegation, caching and split-horizon context; AXFR belongs only in an authorized lab.

- Q3: Public business facts can support convincing pretexts; use awareness mapping, not real-person targeting.
- Q4: Scope, privacy, duplicates, freshness and reliability must be validated.
- Q5: Breadth-first traversal with visited tracking and stop conditions is systematic and bounded.
- Q6: Hybrid passive-first collection balances coverage and operational impact.
- Q7: Early scope and privacy checks reduce unnecessary work and prevent out-of-scope enrichment.

Limitations and future work

Examples are simulated and do not prove a real organization's configuration. Search indexes and archives may be incomplete or stale. Future work should implement a parser, structured evidence database, automated scope checks, real lab query measurements and instructor-approved test fixtures.

REFERENCES, APPENDICES AND SUBMISSION CHECKLIST

References

- NIST SP 800-115, Technical Guide to Information Security Testing and Assessment (2008): https://csrc.nist.gov/pubs/sp/800/115/final
- ICANN Registration Data Lookup / RDAP: https://lookup.icann.org/
- Internet Systems Consortium, BIND 9 Administrator Reference Manual: https://bind9.readthedocs.io/
- RFC 1034, Domain Names – Concepts and Facilities: https://www.rfc-editor.org/rfc/rfc1034
- RFC 1035, Domain Names – Implementation and Specification: https://www.rfc-editor.org/rfc/rfc1035
- RFC 5936, DNS Zone Transfer Protocol (AXFR): https://www.rfc-editor.org/rfc/rfc5936
- RFC 8945, Secret Key Transaction Authentication for DNS (TSIG): https://www.rfc-editor.org/rfc/rfc8945
- OWASP Web Security Testing Guide: https://owasp.org/www-project-web-security-testing-guide/
- CISA, Avoiding Social Engineering and Phishing Attacks: https://www.cisa.gov/
- FIRST, Common Vulnerability Scoring System: https://www.first.org/cvss/

Appendix A – Evidence capture template

Field	Entry
Engagement / authorization ID	_____
Approved domain / target manifest	_____
Tool and version	_____
Command / query	_____
Timestamp / timezone	_____
Resolver / source URL	_____
Raw output file reference	_____
Scope / validation status	_____
Analyst / reviewer	_____